PORTFOLIO: AI-ASSISTED CYBERSECURITY ANALYSIS

(Blue Team)

Mazilu Mihai| AI Cybersecurity Analyst (Beta Tester)

Proiect: Askeal AI Security Operations Validation

INTRODUCEREA PROIECTULUI

Acest document centralizează procesele de investigație și validare tehnică realizate în cadrul programului de testare privată a asistentului AI **Askeal**. Obiectivul principal este demonstrarea modului în care Inteligența Artificială poate accelera detectarea amenințărilor și răspunsul la incidente (Incident Response).

SCENARIUL #01: DETECTAREA MIȘCĂRII LATERALE (PASS-THE-HASH)

Data: 30 Martie 2026

Tehnică MITRE ATT&CK: [T1550.002] Use Alternate Authentication Material: Pass the Hash

A. Ipoteza de Investigare

Identificarea unui atacator care utilizează hash-uri NTLM pentru a se autentifica pe alte mașini din rețea, corelând evenimentele de logare Windows (Event IDs).

B. Interacțiunea cu AI (Prompt)

"Analizează Event ID-urile Windows: 4624 (Logon) corelat cu Event 4648 (Explicit Credentials) pe mașini diferite. Generează o interogare KQL cu logică de Risk Scoring."

C. Rezultat Tehnic (Cod Generat)

Fragment de cod

```
// Exemplu de extras din codul generat:

SecurityEvent

| where EventID == 4624 and LogonType in (3, 9)

| join kind=inner (SecurityEvent | where EventID == 4648) on TargetUserName

| where Computer != Computer1
```

D. Validare și Concluzii

- **Acuratețe:** AI-ul a identificat corect importanța LogonType 9 (NewCredentials).
- **Optimizare:** Am validat excluderea conturilor de sistem pentru a reduce alertele false (False Positives).

SCENARIUL #02: INVESTIGAȚIA L1 A UNUI IP SUSPECT

Data: 1 Aprilie 2026

Tehnică MITRE ATT&CK: [T1071] Application Layer Protocol (C2 Communication)

A. Ipoteza de Investigare Triajul unei alerte de comunicare neobișnuită între PC-CONTABILITATE și un IP extern (185.156.177.22) localizat în Rusia.

B. Rezultat Tehnic (Analiza AI)

- **Reputație:** Curată în bazele de date publice (0/100 AbuseIPDB), dar marcată ca fiind dintr-un centru de date (VPS) din Moscova.
- **Verdict L1:** Alertă suspectă. Reputația neutră poate indica un server C2 nou, neînregistrat încă în blacklists.

C. Acțiuni de Remediere propuse de AI

1. **Izolare fizică:** Deconectarea cablului de rețea/WiFi fără a opri sistemul (pentru a păstra dovezile în memoria RAM).
2. **Identificarea procesului:** Utilizarea comenzii netstat -ano | findstr "185.156.177.22" pentru a identifica PID-ul procesului responsabil de conexiune.
3. **Escaladare:** Raportarea către L2 cu probele colectate (tasklist și netstat output).

SCENARIUL #03: ANALIZĂ FORENSICĂ ATAȘAMENT SUSPECT (HASH HUNTING)

Data: 2 Aprilie 2026

Tehnică MITRE ATT&CK: [T1566.001] Phishing: Spearphishing Attachment / [T1036] Masquerading (Double Extension)

A. Ipoteza de Investigare

Un utilizator a raportat un e-mail suspect ce conține un atașament numit "Factura_Restanta_Martie.pdf.exe". Utilizatorul nu a deschis fișierul. S-a extras hash-ul SHA256 (12ca17b49af2289436f303e0166022a0721c56b50e32f5eb3a1529124430c5e3) pentru a valida natura fișierului și a investiga prezența acestuia în restul rețelei.

B. Interacțiunea cu AI (Prompt)

"Un utilizator a primit un atașament suspect (Factura_Restanta_Martie.pdf.exe). Am extras hash-ul SHA256. 1. Explică tehnica de inginerie socială. 2. Care sunt următorii 3 pași critici în Email Security (ex: Defender)? 3. Cum folosesc acest Hash pentru a căuta fișierul pe alte stații?"

C. Rezultat Tehnic (Analiza AI)

- Analiza Tactică: Extensia ".pdf.exe" exploatează setarea implicită a sistemului de operare Windows de a ascunde extensiile cunoscute. Victima percepe fișierul ca pe un document inofensiv (PDF), declanșând execuția codului malițios.
- Tactică de Inginerie Socială: Urgență și Autoritate (factură restantă).

D. Acțiuni L1 Efectuate (Containment & Hunting)

1. **Blocare la nivel de Tenant:** Introducerea hash-ului SHA256 în Blocklist-ul Microsoft 365 Defender (Safe Attachments).
2. **Hardening Email Gateway:** Activarea "Common Attachment Types Filter" pentru a bloca proactiv și viitoarele încercări de tip "Double Extension".

3. **Threat Hunting:** Rularea unei interogări KQL în Defender for Endpoint pentru identificarea altor potențiale victime:

```
DeviceFileEvents
| where SHA256 == "12ca17b49af2289436f303e0166022a0721c56b50e32f5eb3a1529124430c5e3"
| project DeviceName, FileName, Timestamp, ActionType
```

SCENARIUL #04: INVESTIGAȚIE BRUTE-FORCE ȘI COMPROMITERE CONT (HR)

Data: 6 Aprilie 2026

Tehnică MITRE ATT&CK: [T1110] Brute Force / [T1078] Valid Accounts

A. Ipoteza de Investigare Triajul unei alerte de logări eșuate multiple (Event ID 4625), urmate de o autentificare reușită (Event ID 4624) pentru un cont cu acces la date sensibile (Departamentul HR). Scopul este izolarea contului compromis și investigarea potențialei exfiltrări de date.

B. Interacțiunea cu AI (Prompt) "Am primit o alertă pentru utilizatorul 'maria.popescu' (HR). Văd 45 de încercări de logare eșuate (Event ID 4625) în 3 minute de la un IP extern, urmate de o logare reușită (Event ID 4624) de la același IP. 1. Ce tip de atac este și de ce e critic? 2. Care sunt primii 3 pași exacți pentru securizarea contului? 3. Ce caut în loguri pentru a vedea dacă s-au furat date?"

C. Rezultat Tehnic (Analiza AI)

- **Tip Atac:** Credential Stuffing / Brute-Force. Prezența Evenimentului 4624 transformă alerta dintr-o simplă "tentativă" într-o breșă de securitate confirmată (Compromised Account).
- **Evaluarea Riscului:** Nivel CRITIC. Contul de HR oferă acces la baze de date cu angajați, state de plată și documente personale, existând un risc iminent de exfiltrare de date și încălcare GDPR.

D. Acțiuni L1 Efectuate (Containment & Hunting)

1. **Izolarea Contului:** Dezactivarea imediată a contului din Active Directory pentru a opri accesul atacatorului și forțarea resetării parolei (Event ID 4724).
2. **Izolarea Stației:** Deconectarea stației de lucru a utilizatorului de la rețea pentru a preveni mișcarea laterală sau exfiltrarea în timp real.
3. **Threat Hunting (Post-Compromise):** Monitorizarea logurilor pentru următoarele 60 de minute vizând activități specifice exfiltrării:
    - **Event ID 5140:** Accesarea share-urilor de rețea sensibile (ex: HR_Payroll).
    - **Event ID 4688:** Crearea de procese suspecte de arhivare (7z.exe, rar.exe) sau executare comenzi (powershell.exe).
    - **Event ID 5156:** Conexiuni outbound suspecte către IP-uri externe pe porturi non-standard.

SCENARIUL #05: INSIDER THREAT ȘI DATA LOSS PREVENTION (DLP)

Data: 7 Aprilie 2026

Tehnică MITRE ATT&CK: [T1052.001] Exfiltration Over Physical Medium / [T1048] Exfiltration Over Alternative Protocol

A. Ipoteza de Investigare Triajul unei alerte critice din sistemul DLP: "Mass File Copy to Removable Media". Utilizatorul andrei.vasilescu (Departamentul Vânzări), aflat în perioada de preaviz, a conectat un stick USB și a copiat ~5 GB de date. Scopul este izolarea incidentului la fața locului și securizarea dovezilor digitale.

B. Interacțiunea cu AI (Prompt) "Am primit alertă DLP: Utilizatorul andrei.vasilescu (a depus demisia ieri) a copiat 5 GB de date pe un USB neînregistrat în ultimele 10 minute. 1. Ce tip de amenințare este și care e riscul de business? 2. Care sunt primii 3 pași de izolare (Containment), utilizatorul fiind la birou? 3. Ce Event ID-uri de Windows trebuie să caut pentru a afla numele fișierelor copiate?"

C. Rezultat Tehnic (Analiza AI)

- **Clasificare Amenințare:** Insider Threat Malițios. Tiparul comportamental (copiere masivă de date imediat după demisie) indică intenția de furt de proprietate intelectuală.
- **Riscul de Business:** Nivel CRITIC. Pierderea portofoliului de clienți sau a strategiilor de preț oferă un avantaj direct competitorilor. Implică și posibile încălcări GDPR.

D. Acțiuni L1 Efectuate (Containment & Forensics)

1. **Izolarea Fizică și a Contului:** * Deconectarea fizică a stației Sales-PC-04 de la rețea.
    - Rularea imediată a comenzii PowerShell Disable-ADAccount pentru a preveni accesul la alte resurse (VPN, Email, SharePoint).
    - Notificarea imediată a echipelor HR și Legal pentru interceptarea utilizatorului și confiscarea mediului de stocare (Stick USB), respectând **Chain of Custody** (Lanțul de custodie al probelor).
2. **Conservarea Probelor (Log Preservation):**
    - Păstrarea stației deschise (fără reboot) pentru a nu pierde datele din memoria RAM.
3. **Analiza Forensică (Event IDs):** Utilizarea interogărilor PowerShell (Get-WinEvent) pentru a construi lista exactă a fișierelor exfiltrate:
    - **Event ID 6416:** Validarea momentului exact în care mediul extern a fost conectat la stație.
    - **Event ID 4663:** Identificarea exactă a fișierelor accesate (citite) și mutate pe USB de către utilizatorul andrei.vasilescu.

SCENARIUL #06: INVESTIGAȚIE WEB SECURITY - SQL INJECTION (SQLi)

Data: 8 Aprilie 2026 **Tehnică MITRE ATT&CK:** [T1190] Exploit Public-Facing Application / [T1078] Valid Accounts

A. Ipoteza de Investigare Monitorizarea și triajul alertelor WAF (Web Application Firewall) pentru a identifica un atac de tip SQL Injection pe portalul de login al clienților. Scopul este determinarea succesului atacului pe baza logurilor de trafic HTTP și izolarea imediată a amenințării.

B. Interacțiunea cu AI (Prompt) "Primesc alerte WAF care indică SQL Injection pe login.php de la IP-ul 45.33.22.11. Payload-ul introdus la username este: admin' OR '1'='1' -- . 1. Cum funcționează exact acest payload? 2. La ce coduri HTTP mă uit în loguri pentru a vedea dacă atacul a eșuat sau a avut succes? 3. Care sunt următorii 3 pași de izolare/remediere?"

C. Rezultat Tehnic (Analiza AI)

- **Mecanismul de Atac:** Payload-ul exploatează lipsa sanitizării codului web. Apostroful (') închide prematur variabila de username. Condiția OR '1'='1' este matematic mereu adevărată, forțând o evaluare pozitivă în baza de date. Semnul (--) transformă restul interogării (inclusiv verificarea parolei) într-un simplu comentariu. Rezultatul este un *Authentication Bypass* (autentificare reușită pe contul de admin fără a cunoaște parola).
- **Analiza Logurilor HTTP (Verdict):**
    - **Indicatori de Eșec (Atac Blocat):** Apariția codurilor HTTP 403 (Forbidden - cerere respinsă de WAF) sau HTTP 500 (Internal Server Error - eroare de sintaxă a bazei de date).
    - **Indicatori de Succes (Compromitere):** Apariția codului HTTP 200 (OK) urmat imediat de un HTTP 302 (Redirect) către o pagină internă autentificată (ex: dashboard.php).

D. Acțiuni L1 Efectuate (Containment & Remediation)

1. **Izolare Tactică Rețea:** Blocarea automată (Drop) a traficului provenit de la IP-ul atacator (45.33.22.11) direct din regulile WAF / Firewall perimetral.
2. **Securizarea Sesiunilor:** Invalidarea forțată a tuturor sesiunilor web active asociate cu IP-ul respectiv și resetarea obligatorie a parolei pentru contul de administrator vizat.
3. **Escaladare către Dezvoltare (Remediere Permanentă):** Deschiderea unui tichet de urgență către echipa de Web Development pentru a înlocui codul vulnerabil cu interogări parametrizate (*Parameterized Queries* / *Prepared Statements*), aceasta fiind metoda standard pentru neutralizarea atacurilor de tip SQL Injection.

SCENARIUL #07: MALWARE ANALYSIS & THREAT INTEL (INFOSTEALER)

Data: 10 Aprilie 2026

Tehnică MITRE ATT&CK: [T1547.001] Registry Run Keys / Startup Folder / [T1552] Unsecured Credentials

A. Ipoteza de Investigare Triajul unei alerte EDR pe stația unui dezvoltator software (DEV-Intern-01) privind executarea unui fișier suspect ("Photoshop_Crack_2026.exe"). Validarea comportamentului malițios prin surse OSINT (VirusTotal) pentru identificarea familiei de malware și a riscului de business.

B. Interacțiunea cu AI (Prompt) "EDR-ul a blocat parțial un fișier pe stația unui programator. VirusTotal îl detectează ca RedLine InfoStealer. Din tab-ul Behavior, văd că se copiază în AppData și creează o cheie de Run în Regiștri. 1. Ce date caută un InfoStealer? 2. Ce reprezintă această tactică de modificare a regiștrilor? 3. Care sunt cei 3 pași critici de remediere, având în vedere că e calculatorul unui programator?"

C. Rezultat Tehnic (Analiza AI)

- **Profilul Amenințării (InfoStealer):** Spre deosebire de Ransomware (care distruge), InfoStealer-ul (RedLine) exfiltrează date în tăcere: parole salvate în browser, cookie-uri de sesiune, portofele crypto și, critic pentru mediul Dev, chei SSH și token-uri de Git. Riscul de business este **Compromiterea Lanțului de Aprovizionare (Supply Chain Breach)**.
- **Tactica de Persistență (Autorun Persistence):** Copierea executabilului în folderul *AppData\Roaming* și crearea unei intrări în *HKCU\Software\Microsoft\Windows\CurrentVersion\Run* garantează că virusul se va relansa automat la fiecare pornire a calculatorului, folosind doar privilegiile utilizatorului (fără a necesita drepturi de Administrator).

D. Acțiuni L1 Efectuate (Containment & Forensics)

1. **Izolare Imediată (Fără Reboot):** Deconectarea fizică/logică a stației de la rețea pentru a opri fluxul de exfiltrare a datelor către serverul de Comandă și Control (C2). Sistemul este lăsat pornit pentru a conserva dovezile din memoria RAM (procese active).
2. **Colectare Forensică:** Utilizarea consolei EDR pentru a extrage logurile complete și a identifica indicatorii de compromitere (IoC): cheile de regiștri modificate și căile exacte din folderul AppData.
3. **Remediere și Resetare Masivă (Zero Trust):** Izolarea și ștergerea fișierelor rădăcină din sistem. Măsura critică impusă: resetarea și revocarea imediată a tuturor credențialelor de dezvoltare de pe acea mașină (regenerarea cheilor SSH, revocarea token-urilor GitHub/GitLab, resetarea parolelor de baze de date) pentru a tăia accesul atacatorului la infrastructura internă a companiei.

SCENARIUL #08: CLOUD SECURITY - S3 BUCKET EXPOSURE (DATA LEAKAGE)

Data: 14 Aprilie 2026

Tehnică MITRE ATT&CK: [T1562.007] Disable or Modify Cloud Firewall / [T1530] Data from Cloud Storage

A. Ipoteza de Investigare Triajul unei alerte critice generate de platforma CSPM (Cloud Security Posture Management) privind expunerea publică a unui container de stocare AWS S3 ("client-db-backups-prod"). Scopul este izolarea imediată a containerului, oprirea potențialei exfiltrări de date (Data Leakage) și investigarea originii modificării (Misconfiguration).

B. Interacțiunea cu AI (Prompt) "Primesc o alertă CSPM: AWS S3 Bucket Public Access Enabled pentru bucket-ul 'client-db-backups-prod' (conține baze de date). 1. De ce este o eroare de configurare un incident critic? 2. Ce evenimente caut în AWS CloudTrail pentru a găsi utilizatorul IAM vinovat? 3. Care sunt primii 3 pași de izolare imediată în consola AWS?"

C. Rezultat Tehnic (Analiza AI)

- **Mecanismul de Risc (Cloud Misconfiguration):** Spre deosebire de un atac tradițional unde un sistem este „spart”, aici securitatea este dezactivată accidental (eroare umană) sau intenționat, permițând accesul neautentificat ("Principal": "*") la date sensibile. Riscul de exfiltrare este masiv, declanșând obligativitatea notificării conform GDPR.
- **Analiza Forensică (AWS CloudTrail):** Investigarea se face prin filtrarea evenimentelor de management (Management Events) în CloudTrail, căutând acțiuni specifice de tipul **PutBucketPolicy** sau **PutBucketAcl**. Se extrage câmpul userIdentity.arn pentru a identifica utilizatorul IAM care a efectuat modificarea și sourceIPAddress pentru a valida locația.
- **Investigarea Exfiltrării (Post-Incident):** Verificarea logurilor pentru evenimente de tip **GetObject** pentru a determina dacă un IP extern (sau *Anonymous*) a descărcat arhive din bucket în fereastra de timp în care acesta a fost public.

D. Acțiuni L1 Efectuate (Containment & Remediation)

1. **Izolarea Imediată (Block Public Access):** Accesarea consolei S3 și activarea de urgență a funcției "Block all public access" la nivel de bucket. Această setare acționează ca un kill-switch, suprascriind orice politică publică existentă.
2. **Remedierea Politicilor (Bucket Policy):** Ștergerea manuală a oricărei politici JSON care conține clauza "Principal": "*" sau "Effect": "Allow" neautorizată și setarea ACL-urilor (Access Control Lists) pe "Private".
3. **Auditare și Monitorizare:** Activarea funcției de "Server Access Logging" pentru bucket, pentru a asigura trasabilitatea completă a tuturor cererilor viitoare de descărcare/încărcare.

SCENARIUL #09: ANALIZĂ DE REȚEA (WIRESHARK & PCAP FORENSICS)

Data: 15 Aprilie 2026

Tehnică MITRE ATT&CK: [T1105] Ingress Tool Transfer / [T1071.001] Application Layer Protocol: Web Protocols

A. Ipoteza de Investigare Triajul unei alerte IDS (Intrusion Detection System) privind trafic outbound suspect. Obiectivul este analizarea unui fișier PCAP în Wireshark, decodarea traficului HTTP (Follow TCP Stream) între un IP intern (192.168.10.50) și un IP extern (103.45.67.89), și determinarea intenției malițioase pe baza antetelor HTTP.

B. Interacțiunea cu AI (Prompt) "Am analizat un PCAP cu 'Follow TCP Stream'. Văd trafic de la IP-ul 192.168.10.50 către 103.45.67.89 (port 80). Se face un GET pentru '/update_package_v2.sh' cu User-Agent: curl/7.81.0. 1. Ce tip de atac indică User-Agent-ul și extensia? 2. De ce e un avantaj că traficul este HTTP și nu HTTPS? 3. Care sunt primii 3 pași de izolare?"

C. Rezultat Tehnic (Analiza AI)

- **Identificarea Anomaliei (Malware Dropper):** Traficul nu este generat de un utilizator care navighează legitim. Prezența utilitarului de linie de comandă curl în câmpul *User-Agent* și solicitarea unui script de shell linux (.sh) sunt indicatori de compromitere (IoC) clasici pentru un atac de tip *Malware Downloader / Stager*. O mașină compromisă încearcă să aducă payload-ul final de pe un server de Comandă și Control (C2).
- **Avantajul Analitic (HTTP vs. HTTPS):** Deoarece comunicarea s-a realizat prin portul 80 (necriptat), analiza PCAP permite vizibilitate totală (Cleartext). Ca analist, acest lucru permite extragerea directă a payload-ului, citirea scriptului descărcat și identificarea altor servere C2 sau acțiuni malițioase (ex: stergere loguri), lucru imposibil în cazul traficului HTTPS (port 443) din cauza criptării TLS/SSL.

D. Acțiuni L1 Efectuate (Containment & Forensics)

1. **Izolare Imediată (Fără Oprire):** Deconectarea logică a stației interne de la rețea pentru a bloca transferul tool-urilor malițioase, dar menținerea sistemului pornit pentru a conserva memoria RAM.
2. **Colectarea Probelor Volatile:** Inițierea capturii memoriei RAM pentru analiza forensică (utilizând *Volatility*), esențială pentru a găsi procesul exact care a inițiat comanda curl și posibilele parole stocate în memorie (Cleartext Passwords).
3. **Blocare Perimetrală (Hunt):** Adăugarea IP-ului extern (103.45.67.89) în lista de blocare a Firewall-ului la nivel de companie și interogarea platformei SIEM pentru a verifica dacă și alte stații interne au comunicat cu acest IP.

SCENARIUL #10: VULNERABILITY MANAGEMENT & PRIORITIZARE (CVSS)

Data: 16 Aprilie 2026

Tehnică MITRE ATT&CK: [T1190] Exploit Public-Facing Application / [T1210] Exploitation of Remote Services

A. Ipoteza de Investigare Analizarea unui raport de scanare a vulnerabilităților (Nessus) care indică o vulnerabilitate critică de tip RCE (Remote Code Execution - Log4Shell) pe serverul de producție SRV-WEB-01. Obiectivul este înțelegerea severității (scor CVSS 10.0), aplicarea măsurilor temporare de atenuare și coordonarea procesului de remediere permanentă.

B. Interacțiunea cu AI (Prompt) "Am un raport Nessus cu vulnerabilitatea Log4Shell pe SRV-WEB-01, scor CVSS 10.0. 1. Ce înseamnă scorul 10.0 și de ce e 'Sfântul Graal'? 2. Care e diferența dintre remediere și atenuare? 3. Care sunt cei 3 pași critici de gestionare a vulnerabilității?"

C. Rezultat Tehnic (Analiza AI)

- **Severitate CVSS 10.0 (Impact Maxim):** Vulnerabilitatea are scorul maxim deoarece poate fi exploatată prin rețea (Network), cu o complexitate foarte scăzută (Low), fără privilegii sau autentificare (None) și fără interacțiunea utilizatorului (None), ducând la un impact total asupra Confidențialității, Integrității și Disponibilității serverului.
- **Strategii de Răspuns (Mitigation vs. Remediation):**
    - **Atenuare (Mitigation):** Aplicarea unor măsuri temporare, realizabile în câteva ore, pentru a reduce riscul imediat (ex: reguli de WAF pentru blocarea payload-urilor ${jndi:, filtrarea traficului Egress pe porturile LDAP/RMI). Acestea nu elimină vulnerabilitatea de bază.
    - **Remediere (Remediation):** Soluția permanentă și durabilă care rezolvă problema la nivel de cod (ex: actualizarea bibliotecii Apache Log4j la versiunea 2.17.0+). Necesită testare și ferestre de mentenanță.

D. Acțiuni L1 Efectuate (Vulnerability Lifecycle)

1. **Prioritizare și Escalare:** Documentarea incidentului (CVE-2021-44228) și deschiderea imediată a unui tichet CRITIC către echipele de Security, DevOps și Application Owners.
2. **Implementarea Măsurilor de Atenuare (Containment):** Colaborarea cu echipa de rețea pentru implementarea regulilor WAF și blocarea conexiunilor externe pe porturile sensibile (389, 1099), reducând riscul de exploatare imediată cu ~80%.
3. **Coordonarea Remedierii și Verificarea (Rescan):** Planificarea upgrade-ului alături de echipa de dezvoltare, urmată de o scanare de verificare post-patching (prin trimiterea de payload-uri test) pentru a confirma închiderea cu succes a vulnerabilității.

SCENARIUL #11: EMAIL SPOOFING & FRAUDĂ FINANCIARĂ (BEC)

Data: 20 Aprilie 2026

Tehnică MITRE ATT&CK: [T1566] Phishing / Business Email Compromise

A. Ipoteza de Investigare Triajul unui e-mail suspect raportat de departamentul Financiar, care simulează o cerere de transfer bancar urgent din partea directorului general (CEO). Obiectivul este analizarea headerelor de e-mail (SPF, DKIM, DMARC) pentru a confirma dacă mesajul este o tentativă de fraudă prin falsificare (Spoofing) sau dacă a avut loc compromiterea reală a contului intern.

B. Interacțiunea cu AI (Prompt) "Un angajat raportează un email suspect de la ceo@compania-mea.com. Din headere văd: SPF = FAIL, DKIM = NONE, DMARC = REJECT. 1. Ce tip de atac reprezintă acest scenariu (BEC)? 2. Cum s-a putut trimite un mail cu adresa CEO-ului la expeditor și de ce a picat SPF? 3. Care sunt cei 3 pași de securizare, deși banii nu au fost transferați?"

C. Rezultat Tehnic (Analiza AI)

- **Vectorul de Atac (BEC):** Incidentul este un atac de tip *Business Email Compromise*. Atacatorul vizează angajații cu acces la fonduri, bazându-se pe autoritatea presupusului expeditor și pe urgență (Inginerie Socială).
- **Mecanismul de Spoofing:** Contul CEO-ului NU a fost compromis. Atacatorul a trimis e-mailul de pe propriul server (IP extern), falsificând doar câmpul text "From:".
- **Validarea Autenticității (Analiza DNS):** Protocolul SPF (Sender Policy Framework) a returnat statusul "FAIL" deoarece a verificat înregistrările DNS ale companiei și a constatat că IP-ul atacatorului nu face parte din lista de servere autorizate să trimită e-mailuri în numele domeniului compania-mea.com. Politica DMARC a interceptat corect anomalia.

D. Acțiuni L1 Efectuate (Containment & Awareness)

1. **Validare Out-of-Band:** Contactarea directă a CEO-ului pe un canal alternativ (ex: apel telefonic) pentru a confirma invaliditatea cererii financiare, eliminând suspiciunea compromiterii contului de e-mail.
2. **Implementare Protocol Zero-Trust:** Emiterea unei alerte de securitate (Awareness) către întregul departament Financiar, reamintind procedura standard: orice cerere de transfer inițiată electronic se aprobă doar după o confirmare vocală directă.
3. **Izolare Tactică și Documentare:** Extragerea IP-ului de origine și a serverului SMTP malițios din headerele e-mailului pentru actualizarea listelor de blocare (Blocklist) la nivel de Gateway de E-mail și escaladarea raportului către echipa L2.

SCENARIUL #12: IMPOSSIBLE TRAVEL & COMPROMITERE MFA

Data: 20 Aprilie 2026

Tehnică MITRE ATT&CK: [T1078.004] Valid Accounts: Cloud Accounts / [T1621] Multi-Factor Authentication Request Generation

A. Ipoteza de Investigare Triajul unei alerte de anomalie geografică (Impossible Travel) pentru utilizatorul george.ionescu. Sistemul a detectat două logări reușite: prima din Craiova, România (ora 08:00) și a doua din Lagos, Nigeria (ora 08:30). Scopul este verificarea integrității sesiunii și a mecanismului MFA pentru a confirma compromiterea contului.

B. Interacțiunea cu AI (Prompt) "Am o alertă de 'Impossible Travel' pentru george.ionescu. Logare 1: 08:00 (Craiova). Logare 2: 08:30 (Nigeria). Ambele reușite. 1. De ce distanța/timpul indică o compromitere certă? 2. Ce verific în logurile MFA (MFA Fatigue)? 3. Care sunt cei 3 pași imediați de izolare?"

C. Rezultat Tehnic (Analiza AI)

- **Logica Anomaliei:** Distanța de aproximativ 4.000 - 5.500 km parcursă în doar 30 de minute ar presupune o viteză de deplasare de peste 11.000 km/h. Această viteză este fizic imposibilă pentru un utilizator legitim, confirmând utilizarea simultană a credențialelor de către două entități diferite (utilizator și atacator).
- **Analiza Compromiterii MFA:** Deoarece ambele logări sunt marcate ca „Succeeded”, incidentul indică fie un atac de tip **MFA Fatigue** (utilizatorul a aprobat o notificare push din eroare), fie **Session Hijacking** (furtul unui token de sesiune deja autentificat). Investigația trebuie să se concentreze pe *Timestamp-ul* aprobării MFA și pe identificarea *Device ID-ului* care a furnizat aprobarea.

D. Acțiuni L1 Efectuate (Remediere)

1. **Revocarea Sesiunilor Active:** Utilizarea funcției "Revoke all sessions" în consola de administrare (ex: Azure AD / Okta) pentru a invalida imediat toate token-urile de acces și a deconecta atacatorul.
2. **Resetarea și Re-înrolarea MFA:** Resetarea metodelor de autentificare multifactor pentru a asigura eliminarea oricărui dispozitiv neautorizat înregistrat de atacator și forțarea unei noi parole complexe.
3. **Izolarea Contului și Validarea Out-of-Band:** Dezactivarea temporară a contului și contactarea telefonică a utilizatorului pentru a confirma incidentul și a-l instrui cu privire la pericolele aprobării notificărilor push neinițiate de el.

SCENARIUL #13: INVESTIGAREA UNUI FALSE POSITIVE (ALARMĂ FALSĂ)

Data: 21 Aprilie 2026

Tehnică MITRE ATT&CK: [T1059.001] Command and Scripting Interpreter: PowerShell

A. Ipoteza de Investigare Triajul unei alerte EDR de severitate critică privind execuția unei comenzi PowerShell encodate pe un server de management (IT-MGMT-SRV-01). Obiectivul este determinarea naturii malițioase sau legitime a scriptului prin decodificarea comenzii și analiza contextului de execuție pentru a reduce "zgomotul" alertelor inutile.

B. Interacțiunea cu AI (Prompt) "EDR-ul indică 'Suspicious Encoded PowerShell' pe serverul IT-MGMT-SRV-01. Comanda este: powershell.exe -EncodedCommand J2dldC1zZXJ2aWNlIHwgd2hlcmUgeyRfLlN0YXR1cyAtZXEgIlN0b3BwZWQifSc=. 1. Decodifică comanda. 2. Cum verific dacă e legitimă (utilizator, proces părinte)? 3. Cum sună recomandarea de Tuning dacă este False Positive?"

C. Rezultat Tehnic (Analiza AI)

- **Decodificare Payload:** Comanda decodificată din Base64 este: "get-service | where {$_.Status -eq 'Stopped'}". Aceasta este o funcție administrativă inofensivă care interoghează starea serviciilor de sistem.
- **Analiza Contextuală (Verdict):** Deși utilizarea parametrului "-EncodedCommand" este suspectă (tehnică de evaziune), contextul de execuție confirmă legitimitatea: procesul este lansat de utilizatorul "SYSTEM", are ca părinte "svchost.exe" și se execută zilnic la aceeași oră (02:00 AM).
- **Concluzie:** False Positive (FP). Activitate de monitorizare automată legitimă.

D. Acțiuni L1 Efectuate (Tuning & Mentenanță)

1. **Validarea Surselor:** Confirmarea cu echipa de IT Operations că serverul IT-MGMT-SRV-01 are setat un "Scheduled Task" pentru inventarierea serviciilor.
2. **Recomandare de Whitelisting (Tuning):** Solicitarea către echipa L2 de a crea o regulă de excludere în EDR. Aceasta trebuie să permită execuția comenzii doar pe serverul vizat, sub contul SYSTEM, eliminând alertele viitoare pentru acest comportament specific.
3. **Îmbunătățirea Vizibilității:** Sugerarea echipei de administratori să modifice scriptul pentru a rula comanda în clar (fără encodare Base64), conform bunelor practici de securitate, pentru a nu declanșa regulile de detecție a obfuscării.

SCENARIUL #14: DETECTARE TIMPURIE RANSOMWARE (SHADOW COPIES DELETION)

Data: 22 Aprilie 2026

Tehnică MITRE ATT&CK: [T1490] Inhibit System Recovery / [T1036.005] Masquerading: Match Legitimate Name or Location

A. Ipoteza de Investigare Identificarea unei activități de severitate critică pe serverul financiar FIN-SRV-02, vizând distrugerea mecanismelor de recuperare a datelor. Detectarea execuției utilitarului vssadmin.exe pentru ștergerea copiilor de rezervă locale (Shadow Copies), acțiune care precede imediat faza de criptare masivă a unui atac de tip Ransomware.

B. Interacțiunea cu AI (Prompt) "Alertă critică: Shadow Copies Deletion pe FIN-SRV-02 prin comanda 'vssadmin.exe delete shadows /all /quiet'. 1. De ce e un semnal de Ransomware iminent? 2. Ce indică procesul părinte svchost.exe din C:\Users\Public? 3. Care sunt cei 3 pași de izolare în primele 60 de secunde?"

C. Rezultat Tehnic (Analiza AI)

- **Analiza Precursorului de Atac:** Comanda vssadmin.exe delete shadows /all /quiet este „semnalul roșu” final. Hackerii o folosesc pentru a forța victima să plătească răscumpărarea, eliminând orice posibilitate de restaurare a fișierelor prin funcția "Previous Versions" din Windows.
- **Detectarea Masquerading-ului:** Procesul părinte svchost.exe care rulează din folderul C:\Users\Public\ este un indicator cert de compromitere (IoC). În mod legitim, acest proces de sistem rulează exclusiv din C:\Windows\System32\. Prezența sa într-un folder public indică un malware care încearcă să se deghizeze pentru a evita detecția vizuală în Task Manager.

D. Acțiuni L1 Efectuate (Incident Response - High Urgency)

1. **Izolarea Fizică/Logică (0-15s):** Deconectarea imediată a serverului FIN-SRV-02 de la rețea pentru a opri procesul de criptare (dacă acesta a început) și pentru a preveni propagarea laterală către restul infrastructurii.
2. **Terminarea Procesului Malițios (15-40s):** Identificarea și oprirea forțată a procesului suspect din folderul Public. Această acțiune este vitală pentru a limita volumul de date care apucă să fie criptat.
3. **Auditarea și Securizarea Backup-urilor (40-60s):** Verificarea integrității sistemelor de backup externe (offline/immutable) și asigurarea că acestea nu sunt accesibile de pe serverul compromis, pentru a garanta o cale sigură de restaurare.